

#	Department	Priority	Finding / Task	File / Component	Recommended Action	Est. (Hours)	Status
1	Frontend	CRITICAL	Hardcoded password shipped in JS bundle	src/lib/managementAccess.ts	Remove password; implement real server-side authentication (Entra ID / SSO)	16	Must have
2	Frontend	CRITICAL	Document Inbox and Detail routes fully unprotected	src/pages/DocumentInbox.tsx, DocumentDetail.tsx	Gate or protect all routes server-side once real auth is in place	6	Must have
3	Frontend	HIGH	No Authorization headers on proxy calls	src/lib/aiExtraction.ts	Send Bearer token or session cookie on every sensitive request	10	Must have
4	Frontend	HIGH	VITE_* env vars embedded in client build	vite.config.ts / .env	Treat all VITE_* values as public; inject runtime config via trusted server endpoint	4	Must have
5	Frontend	MEDIUM	Unencrypted PII in localStorage / sessionStorage	AppContext.tsx, multiple pages	Minimise PII in browser storage; clear on logout	2	Must have
6	Frontend	MEDIUM	Dev server binds to all interfaces (host: "::")	vite.config.ts	Restrict to 127.0.0.1 outside shared dev environments	1	Must have
7	Frontend	CRITICAL	Large Component Refactor	src/pages/DocumentDetail.tsx, src/pages/DocumentInbox.tsx	Split line component into features/hooks/services/components	26	Must have
8	Frontend	MEDIUM	React-router open redirect CVEs	package.json — react-router 6.30.1	Upgrade to 6.30.4	0.5	Must have
9	Frontend	MEDIUM	postcss XSS via style tags	package.json — postcss 8.5.6	Upgrade to 8.5.10	0.5	Must have
10	Frontend	HIGH	Five HIGH CVEs in @xmldom/xmldom	package.json — @xmldom/xmldom 0.8.11	Upgrade to 0.8.13 (0.8.x) or 0.9.10 (0.9.x)	1	Must have
11	Frontend	HIGH	XSS in @remix-run/router	package.json — @remix-run/router 1.23.0	Upgrade to 1.23.2	1	Must have
12	Backend	CRITICAL	Management gate is client-side only (sessionStorage)	src/lib/managementAccess.ts, Sidebar.tsx	Move auth enforcement to backend; treat frontend gate as UX only	14	Must have
13	Backend	CRITICAL	Unauthenticated management unlock function	src/lib/managementAccess.ts:16	Add server-side auth check, rate limiting and audit log before unlock is granted	5	Must have
14	Backend	CRITICAL	AI proxy has no authentication	server/ai-proxy.mjs — all endpoints	Require signed JWT or API key verified server-side on every endpoint	7	Must have
15	Backend	HIGH	CORS origin derived from user input	server/ai-proxy.mjs:21, :67	Replace with a fixed server-side origin allowlist; never derive from request	8	Must have
16	Backend	HIGH	Arbitrary code execution in lodash	package.json — lodash 4.17.21	Upgrade to 4.18.1 (fixes all 3 lodash CVEs)	1	Must have
17	Backend	HIGH	Command injection via glob	package.json — glob 10.4.5	Upgrade to 10.5.0	1	Must have
18	Backend	HIGH	ReDoS in minimatch (3 CVEs)	package.json — minimatch 9.0.5	Upgrade to 9.0.7	1	Must have
19	Backend	HIGH	ReDoS / injection in picomatch	package.json — picomatch 2.3.1	Upgrade to 2.3.2	1	Must have
20	Backend	HIGH	Prototype pollution + ReDoS in xlsx	package.json — xlsx 0.18.5	Upgrade to 0.20.2	1	Must have

#	Department	Priority	Finding / Task	File / Component	Recommended Action	Est. (Hours)	Status
21	Backend	MEDIUM	Verbose error responses leak stack traces	server/ai-proxy.mjs	Return generic errors to clients; write detail to internal logs only	4	Must have
22	Backend	MEDIUM	ReDoS via non-literal RegExp	server/ai-proxy.mjs, src/lib/remarkDetection.ts	Replace dynamic RegExp() with literal patterns or validated input	1	Must have
23	Backend	MEDIUM	uuid output buffer issue	package.json — uuid 8.3.2	Upgrade to 14.0.0	1.5	Must have
24	Backend	MEDIUM	brace-expansion DoS	package.json — brace-expansion 2.0.2	Upgrade to 2.0.3	0.5	Must have
25	Backend	MEDIUM	yaml DoS via nested parsing	package.json — yaml 2.6.0	Upgrade to 2.8.3	1	Must have
26	Backend	CRITICAL	No authentication on AI proxy endpoints	server/ai-proxy.mjs	Add JWT or API key validation middleware before any route handler	10	Must have
27	Backend	HIGH	No HTTPS/TLS enforcement in server logic	server/ai-proxy.mjs	Enforce HTTPS at infrastructure level; reject plain HTTP	6	Must have
28	Backend	MEDIUM	Monolithic ~4,500-line proxy file	server/ai-proxy.mjs	Refactor into route modules and service layers	22	Must have
29	Database	CRITICAL	No Row-Level Security — all users see all rows	Azure SQL — all customer tables	Implement RLS predicates using SESSION_CONTEXT per tenant	24	Must have
30	Database	CRITICAL	No Column-Level Security on sensitive fields	Azure SQL — pricing, PII columns	Apply CLS via DENY grants or dynamic data masking	16	Must have
31	Database	MEDIUM	Missing NOT NULL constraints on business columns	Azure SQL schema	Enforce NOT NULL and CHECK constraints on critical columns	10	Must have
32	Database	MEDIUM	Foreign key gaps on junction and audit tables	Azure SQL schema	Add referential integrity constraints to all junction tables	17	Must have
33	Database	MEDIUM	No soft-delete pattern	Azure SQL schema	Add DeletedAt column and view-level filtering for legal hold entities	19	Must have
34	DevOps / Infra	CRITICAL	Container process runs as root	Dockerfile:19	Add USER nonroot directive	1	Must have
35	DevOps / Infra	CRITICAL	No CI/CD pipeline	GitHub / repository	Set up GitHub Actions pipeline with build, test, security gate stages	8	Must have
36	DevOps / Infra	HIGH	No secret scanning gate in pipeline	GitHub Actions	Add Gitleaks step; fail build on detected secrets	4	Must have
37	DevOps / Infra	HIGH	No dependency scanning gate in pipeline	GitHub Actions	Add Trivy step; fail build on HIGH/CRITICAL CVEs	4	Must have
38	DevOps / Infra	HIGH	Secrets managed via .env files	server/.env, container env	Migrate all secrets to Azure Key Vault; inject at runtime via Managed Identity	6	Must have
39	DevOps / Infra	HIGH	No secret rotation policy	Azure / Key Vault	Define rotation schedule; enforce via Key Vault rotation policies	1	Must have
40	DevOps / Infra	HIGH	No RBAC governance across Azure resources	Azure subscription	Enforce least-privilege RBAC per resource; replace IP whitelisting with private endpoints	6	Must have
41	DevOps / Infra	HIGH	Database access via informal IP whitelist	Azure SQL firewall	Replace with VNet private endpoint and Managed Identity auth	5	Must have

#	Department	Priority	Finding / Task	File / Component	Recommended Action	Est. (Hours)	Status
42	DevOps / Infra	HIGH	No environment separation	Azure resources	Create separate resource groups for Dev/Preview, Staging and Production	12	Must have
43	DevOps / Infra	MEDIUM	No centralised logging or monitoring	Azure / application	Set up Log Analytics workspace, Application Insights and metric-based alerting	15	Must have
44	DevOps / Infra	MEDIUM	SPA and API bundled in single Dockerfile	Dockerfile	Separate frontend and backend into independent containers which increases security	9	Must have
45	Cyber Security	CRITICAL	Hardcoded credential in source code	src/lib/managementAccess.ts:2	Rotate immediately; remove from source and git history (git filter-repo); store in Azure Key Vault	6	Must have

Quality Assurance

Following the completion of frontend, backend, and database remediation tasks — which include server-side authentication enforcement (Entra ID / SSO integration, JWT-based API security), React component architecture refactoring, AI proxy hardening, Azure SQL Row-Level and Column-Level Security implementation, and dependency vulnerability patching — a structured QA cycle will be executed across all affected system layers. QA effort has been estimated at approximately 50% of the frontend implementation effort (60 hours) and is scoped to validate the correctness, stability, and security posture of every remediated item.

- **Smoke testing** — Core application flows — document ingestion, Outlook sync, and AI extraction — are verified to remain fully operational after each remediation phase is deployed.
- **Regression testing** — Changes to the authentication layer, AI proxy endpoints, and Azure SQL schema are tested to confirm no regressions are introduced in existing frontend features or backend service behaviour.
- **Validation of authentication and authorization flows** — End-to-end testing of Entra ID / SSO integration, JWT enforcement on every proxy endpoint, backend session management, and route-level access controls covering both the Document Inbox and Document Detail views.
- **Verification of critical business processes** — Document processing pipelines, pricing data access, customer PII handling, and Salesforce / Azure integration workflows are confirmed to operate correctly under the remediated access control and input validation model.
- **Security-focused functional testing** — Targeted functional tests are executed against all remediated vulnerability points, including CORS policy enforcement, Content-Security-Policy headers, Row-Level Security predicates, Column-Level Security grants, input schema validation, and file upload content inspection.
- **Post-remediation verification** — Structured retesting against the original remediation task list confirms resolution of all CRITICAL and HIGH findings, with sign-off evidence captured for each item prior to production deployment.

Effort Estimates Summary

- Frontend, Backend, and Database: **239 hours**
- DevOps and Infrastructure: **71 hours**
- Cyber Security: **6 hours**
- Quality Assurance: **20 hours**

Total Estimated Effort: 336 hours